AuthzLedger / selective retest evidence

Assessment

Title

AuthzLedger / selective retest evidence

Assessment ID

demo-c-selective100

Reviewer

Synthetic demonstration runner

Period

Retained execution timestamps

Snapshot

7d2eac64eea20a2d4e54b8291b6309ac41c7ca5c9d7c85673f03dc60222df227

Renderer

assessment-html-pdf-v1-reportlab-4.4.9-dejavu-2.37

Executive summary

Summary

100 baseline requests; 7 selected checks plus 3 fresh prerequisite controls; 90 cases remain not_retested.

Finding status

{"candidate": 0, "confirmed": 0, "rejected": 0, "retest_pending": 0, "retest_verified": 7}

Scope and methodology

Scope

http://127.0.0.1:45139

Method

Explicit rules, source-bound requests and valid controls. Evidence remains local; observations are reviewed at their recorded verification level.

Coverage

[{"comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "dependency_cases": 3, "not_retested_cases": 90, "retested_cases": 10, "selected_cases": 7, "source_cases": 100}]

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-1a3df35e5a24cf5ba97950c8

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-2

Reproduction

GET /invoice/A?view=2 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

c53d850d2666e84a7247af4e8dadfb75bff530050580d03f96b34003e83508d8

Source report root

24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a

Finding record digest

3f6cd6967658e1bd64335a970364a7621316c46e1b0f1445f372c74813ec71e7

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "2d44e0877c5371f3db9536c01cd42f1ee82087a55de86efcfc90d58488258f5e", "case_id": "target-2", "comparison_digest": "ae9c7e635757cf70919dcdc1f8c7d088a61884820096a032636d8b0f9f0b39c5", "comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "current_root": "24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-3ace0e8f12001e15834c8592

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-1

Reproduction

GET /invoice/A?view=1 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

45e97bc2402e00d989b67c9edf5269b52207fb21568561cc315deeef39bddfc9

Source report root

24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a

Finding record digest

577136445676b9cd266f572fd272b5d9a2ffe8984b06bb01dea64f2194d22af7

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "2d44e0877c5371f3db9536c01cd42f1ee82087a55de86efcfc90d58488258f5e", "case_id": "target-1", "comparison_digest": "ae9c7e635757cf70919dcdc1f8c7d088a61884820096a032636d8b0f9f0b39c5", "comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "current_root": "24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-3b808dceafc6e1325bf3b601

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-3

Reproduction

GET /invoice/A?view=3 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

f3d2efc5592af1e9a9aba223636636adf1b1d7a206e66ed82467b42de1ac0598

Source report root

24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a

Finding record digest

030806ff58f6d0e9626ca3851dd4ec7e51a4aa5bf81e970ff4724fb7ef2d8aa2

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "2d44e0877c5371f3db9536c01cd42f1ee82087a55de86efcfc90d58488258f5e", "case_id": "target-3", "comparison_digest": "ae9c7e635757cf70919dcdc1f8c7d088a61884820096a032636d8b0f9f0b39c5", "comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "current_root": "24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-47ea938498ef7edb6494607a

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-4

Reproduction

GET /invoice/A?view=4 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

b0b71910a009e121ad58658b0d7bad1d212812d94ac4b5dec21b41722d9e5039

Source report root

24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a

Finding record digest

0af1b9cd0a9fdffaef0be22292f42273d31fa273c14334a1b0662fadb46652da

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "2d44e0877c5371f3db9536c01cd42f1ee82087a55de86efcfc90d58488258f5e", "case_id": "target-4", "comparison_digest": "ae9c7e635757cf70919dcdc1f8c7d088a61884820096a032636d8b0f9f0b39c5", "comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "current_root": "24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-5c0e74f8b65f0c26dd5b3d6a

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-0

Reproduction

GET /invoice/A?view=0 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

21b99b388defe99f69a52249c90af131d38771b324fe0cfd55174cab1dc9c1db

Source report root

24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a

Finding record digest

7217b14a131d147f985352b1b341352e1c90c1321e75fef759270447cc8c7e10

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "2d44e0877c5371f3db9536c01cd42f1ee82087a55de86efcfc90d58488258f5e", "case_id": "target-0", "comparison_digest": "ae9c7e635757cf70919dcdc1f8c7d088a61884820096a032636d8b0f9f0b39c5", "comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "current_root": "24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-91acb888cf876e88c941448b

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-6

Reproduction

GET /invoice/A?view=6 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

f302016614953de99e8d55ce4b395061590e6a67fa8b5552a8f73384c42827b2

Source report root

24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a

Finding record digest

3c666e43cab758528d35da0210936382044c7404058090aef6415d5c24faa9c6

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "2d44e0877c5371f3db9536c01cd42f1ee82087a55de86efcfc90d58488258f5e", "case_id": "target-6", "comparison_digest": "ae9c7e635757cf70919dcdc1f8c7d088a61884820096a032636d8b0f9f0b39c5", "comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "current_root": "24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-bfbf3a14c81af91f4f1e87ac

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-5

Reproduction

GET /invoice/A?view=5 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

850d0a846474133e23e763bb0d0835763485b3d506ffd521b02e89be326b6c72

Source report root

24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a

Finding record digest

0010f7e75cb576c9308f62440c840b5ea00e6b4800869fff7f7bc415166191b0

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "2d44e0877c5371f3db9536c01cd42f1ee82087a55de86efcfc90d58488258f5e", "case_id": "target-5", "comparison_digest": "ae9c7e635757cf70919dcdc1f8c7d088a61884820096a032636d8b0f9f0b39c5", "comparison_sha256": "fa0668eab81b2da607a0f7bb4789a660f0245d0e38d4392146eb31258e44e025", "current_root": "24cea2533c7ae299f6697b368015012d60090c618fbd99e6b8eac96ebde26d1a", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Standards profile

API 2023

https://api-security.owasp.org/editions/2023/en/0x11-t10/

ASVS 5.0.0

https://github.com/OWASP/ASVS/tree/v5.0.0

CVSS 4.0

https://www.first.org/cvss/v4.0/specification-document

WSTG 4.2

https://wstg.owasp.org/v4.2/

Limitations and independent verification

Limitation

This is a scoped assessment, not certification or complete ASVS/WSTG/API coverage.

Limitation

Finding status, technical severity and business risk are separate dimensions.

Limitation

A restored configured check is not automatically a verified vulnerability fix.

Limitation

Retest omissions retain not_retested and historical evidence only.

Limitation

Signatures authenticate retained bytes and signing keys; they do not prove remote execution truth.

Limitation

Replayed oracle inputs are approved projections; their relationship to unavailable raw response bytes remains signer-attested.

Limitation

The standalone verifier provides integrity_only; semantic verification requires AuthzLedger and the pinned report renderer.

Limitation

Seven explicit query variants share one synthetic resource, identity and rule.

Limitation

The 90 remaining baseline cases are historical, not evidence of a current fix.

Limitation

100 to 10 compares dispatched requests within this fixture; it is not a general speedup benchmark.

Limitation

Server receipts are local measurements by this runner, not third-party execution attestations.

Limitation

Setup, cleanup, replay, reduction, PDP, advisory and state probes make no HTTP requests here.

Verify

Obtain the public-key fingerprint through an independent trusted channel. Run: python3 -I verify_bundle.py PACKAGE --public-key TRUSTED.pem. The package manifest supplies the signer fingerprint. Then run AuthzLedger verify-bundle for retained evidence and exact report semantics. Never trust a key solely because it is inside the package.